



Uscribe

Security Review

Cantina Managed review by:

Hyh, Lead Security Researcher

Ladboy233, Security Researcher

March 19, 2025

Contents

1	Introduction	2
1.1	About Cantina	2
1.2	Disclaimer	2
1.3	Risk assessment	2
1.3.1	Severity Classification	2
2	Security Review Summary	3
3	Findings	4
3.1	Medium Risk	4
3.1.1	Document that UScribe consumer should ensure signature replay protection and timestamp validation	4
3.2	Informational	4
3.2.1	Document that the wat() should return _wat when the function wat() is overwritten	4

1 Introduction

1.1 About Cantina

Cantina is a security services marketplace that connects top security researchers and solutions with clients. Learn more at cantina.xyz

1.2 Disclaimer

Cantina Managed provides a detailed evaluation of the security posture of the code at a particular moment based on the information available at the time of the review. While Cantina Managed endeavors to identify and disclose all potential security issues, it cannot guarantee that every vulnerability will be detected or that the code will be entirely secure against all possible attacks. The assessment is conducted based on the specific commit and version of the code provided. Any subsequent modifications to the code may introduce new vulnerabilities that were absent during the initial review. Therefore, any changes made to the code require a new security review to ensure that the code remains secure. Please be advised that the Cantina Managed security review is not a replacement for continuous security measures such as penetration testing, vulnerability scanning, and regular code reviews.

1.3 Risk assessment

Severity	Description
Critical	<i>Must fix as soon as possible (if already deployed).</i>
High	Leads to a loss of a significant portion (>10%) of assets in the protocol, or significant harm to a majority of users.
Medium	Global losses <10% or losses to only a subset of users, but still unacceptable.
Low	Losses will be annoying but bearable. Applies to things like griefing attacks that can be easily repaired or even gas inefficiencies.
Gas Optimization	Suggestions around gas saving practices.
Informational	Suggestions around best practices or readability.

1.3.1 Severity Classification

The severity of security issues found during the security review is categorized based on the above table. Critical findings have a high likelihood of being exploited and must be addressed immediately. High findings are almost certain to occur, easy to perform, or not easy but highly incentivized thus must be fixed as soon as possible.

Medium findings are conditionally possible or incentivized but are still relatively likely to occur and should be addressed. Low findings a rare combination of circumstances to exploit, or offer little to no incentive to exploit but are recommended to be addressed.

Lastly, some findings might represent objective improvements that should be addressed but do not impact the project's overall security (Gas and Informational findings).

2 Security Review Summary

Chronicle Protocol is a blockchain-agnostic layer for securely and verifiably transitioning data onchain.

From Mar 5th to Mar 8th the Cantina team conducted a review of [uscribe](#) on commit hash [3b4ba5d2](#). The team identified a total of **2** issues:

Issues Found

Severity	Count	Fixed	Acknowledged
Critical Risk	0	0	0
High Risk	0	0	0
Medium Risk	1	1	0
Low Risk	0	0	0
Gas Optimizations	0	0	0
Informational	1	1	0
Total	2	2	0

3 Findings

3.1 Medium Risk

3.1.1 Document that UScribe consumer should ensure signature replay protection and timestamp validation

Severity: Medium Risk

Context: UScribe.sol#L146-L149

Description:

```
function constructChronicleSignedMessage(
    bytes32 scheme,
    UPokeData calldata uPokeData
) public view returns (bytes32) {
    return keccak256(
        abi.encodePacked(
            "\x19Chronicle Signed Message:\n32",
            keccak256(
                abi.encodePacked(
                    scheme, _wat, uPokeData.payload, uPokeData.proofURI
                )
            )
        )
    );
}
```

The signature schema does not include a incremented `nonce` or `block.chain` or `address(this)`. The the UScribe smart contract, the system does not enforce unique signature checks, allowing potential replay attacks or cross-chain replay attack. There is no strict validation of signature timestamps, which may allow expired or future-dated signatures.

Recommendation: Document that UScribe consumer contract should ensure signature replay protection and timestamp validation.

Chronicle Labs: Fixed in [PR 2](#).

Cantina Managed: Fix verified.

3.2 Informational

3.2.1 Document that the `wat()` should return `_wat` when the function `wat()` is overwritten

Severity: Informational

Context: UScribe.sol#L164-L166

Description: UScribe consumer has to overwrite the function.

```
function wat() public view virtual returns (bytes32) {
    return _wat;
}
```

But this value is immutable (cannot be changed after the constructor initialization), and `_wat` is used in the signature schema.

```
abi.encodePacked(
    scheme, _wat, uPokeData.payload, uPokeData.proofURI
)
```

Then the `wat()` should return `_wat` when the function `wat()` is overwritten.

Recommendation: Document that `wat()` should return `_wat` when the function `wat()` is overwritten to match the value `_wat` in signature schema.

Chronicle Labs: Fixed in [PR 2](#).

Cantina Managed: Fix verified.